$ ./hunt --hypothesis clickfix && ./write --report

WRITING THE INCIDENT STORY



David Pérez

Threat Intelligence & Threat Hunting

DEATHCON 2026 · WORKSHOP · NOVEMBER 13–14

OPENING

The workshop in one hour

01	Opening	3 min
02	Why the report matters	5 min
03	Threat hunting in ten minutes	10 min
04	The ClickFix case: from the lure to the only alert	10 min
05	The hunt in Microsoft Sentinel	12 min
06	**Writing the story**	**15 min · the heart of the workshop**
07	Your turn: the exercise	5 min

OPENING

Who am I?



David Pérez · Anakin

Threat Intelligence & Threat Hunting

CAREER

SOC Analyst (L1, L2) → Phishing Analyst → Threat Intelligence, Threat Hunter and Incident Response. Today, SOC and IR lead.

GOVERNMENT

Criminal intelligence (Information Collection Area) and Analysis and Counterintelligence Dept., Ministry of Justice of Buenos Aires.

TOPICS I FOLLOW

Threat intelligence, ransomware, the initial access ecosystem and leaks in LATAM.

CERTIFICATIONS

eCIR · eCTHP (INE Security) · CTIA · ECIH (EC-Council) · CCFA (CrowdStrike) · SC-200 (Microsoft) · CC (ISC²)

CONTACT

@anakinswal · github.com/Ank1nskywalker/talks · perez.edav@gmail.com

WHY WE ARE HERE

A hunt without a report never happened.

The query gets lost. The report stays.

WHY THE REPORT MATTERS

Who reads your report?

The decision-maker

Management or CISO

What happened, what the risk is and what they need to approve. Reads one page.

The SOC

Analysts and detection engineering

The queries, the IOCs and the rules that remain.

The next hunter

Whoever repeats the hunt in six months

What was searched, how, and what could not be seen.

The auditor

Client or compliance

Proof that you looked, even if nothing was found.

Write for the decision-maker; document for the other three.

WHY THE REPORT MATTERS

A report answers three questions, whether you find something or not

What happened?

Findings with a verdict and evidence.

→ Findings and executive summary

What didn’t we see?

Scope, limitations and confidence level.

→ Scope and limitations

What changes tomorrow?

Detections, actions with an owner and the next hypothesis.

→ Recommendations and action plan

What threat hunting is not

Not waiting for the alert

If you start when the alarm goes off, you are responding, not hunting.

Not triage

Working the SIEM queue is necessary, but those are alerts someone already wrote.

Not sweeping IOCs

Searching a feed's hashes is useful, short-lived and needs no hypothesis.

Not incident response

IR starts from a certainty: something happened. Hunting starts from a doubt.

Threat hunting is the **proactive, iterative** search for threats that **evaded existing controls**.

Assume breach · Start from a hypothesis · End with something new

Source: Sqrrl, "A Framework for Cyber Threat Hunting" · Bianco et al., PEAK (Splunk SURGe, 2023)

Three ways to hunt

TODAY'S

Intelligence-driven

Starts from outside. A report, a feed or a PIR tells you what is happening, and you translate its TTPs, not its IOCs, into a question for your fleet.

Example: ClickFix was 47% of initial access. Did anyone in the fleet paste a command?

ATT&CK

Hypothesis-driven

Starts from an idea, with no report to trigger it: you start from ATT&CK or your own experience. "If the adversary did X, I would see it in Y."

Example: if someone persists in the browser, a process that is not Chrome will write its profile.

EXPLORATORY

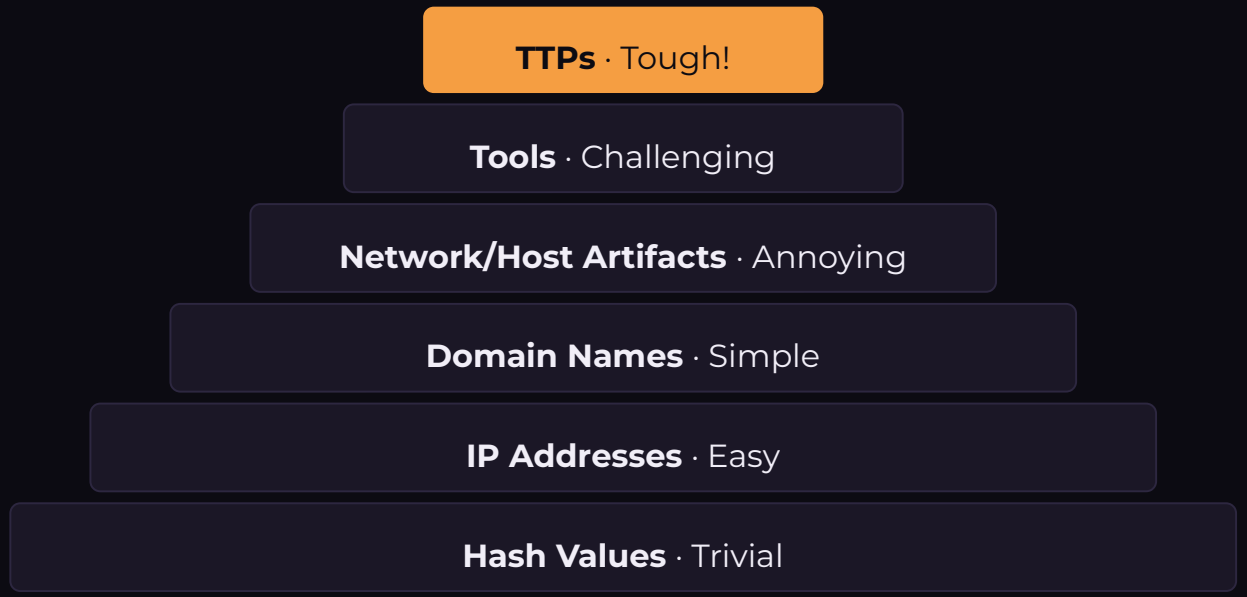
Baseline

Starts from the data. You define normal and hunt the odd: stack counting, rarity across the fleet, things seen only once.

Example: how many times a month does csc.exe run with no arguments across 3,000 hosts?

Adapted from PEAK (Bianco et al., Splunk SURGe, 2023)

The Pyramid of Pain



In this case

Hash · trivial

The script's hash changed on every download.

Domain · simple

The stage-1 domain no longer resolved days after we captured it.

TTP · tough

The behavior did not change: paste, hide the console, inject into .NET and persist in the browser.

Source: D. J. Bianco, "The Pyramid of Pain" (2013)

THREAT HUNTING IN TEN MINUTES

The hunt cycle

PREPARE		EXECUTE		ACT
1 **Hypothesis** What would the adversary do, and where would I see it? **In the case** *A user pasted a ClickFix command.*	**2** **Data** Do I have the telemetry? What can't I see? **In the case** *Processes, network, files and registry. Not the clipboard.*	**3** **Query** Does it find what I know exists? **In the case** *Tested against a positive control.*	**4** **Analysis** Malicious, benign or inconclusive? **In the case** *Every result, with its verdict.*	**5** **Report** What changes tomorrow? **In the case** *Detections, gaps and the next hypothesis.*

↻ **The report feeds step 1:** every hunt leaves the next hypothesis.

Prepare / Execute / Act phases of the PEAK framework (Splunk SURGe, 2023)

THE CLICKFIX CASE

ClickFix: why it is the hypothesis

47%

of the initial access cases seen by Microsoft Defender Experts were ClickFix. Phishing: 35%.

Microsoft, DDR 2025

+517%

between H2 2024 and H1 2025: the second vector, behind phishing.

ESET, H1 2025

4 in 5

payloads intercepted in 2026 arrived from a search engine, not from email.

Push Security, 2026

17,000+

URLs with fake verification pages analyzed; about 3,000 active.

CTM360, Sep 2026

HOW IT WORKS

1 · You search

Music, software, a “fix”.

2 · A fake error

A CAPTCHA, “verify you are human”.

3 · It copies a command

The page leaves it on the clipboard.

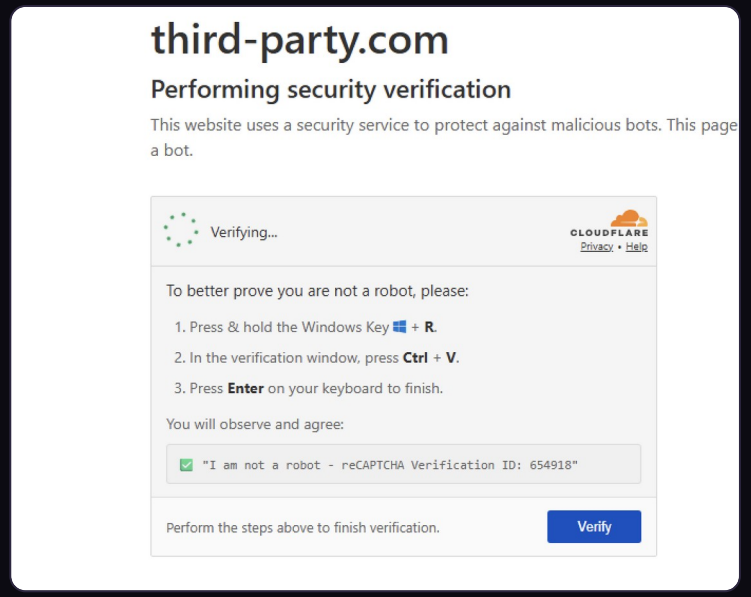
4 · Paste and Enter

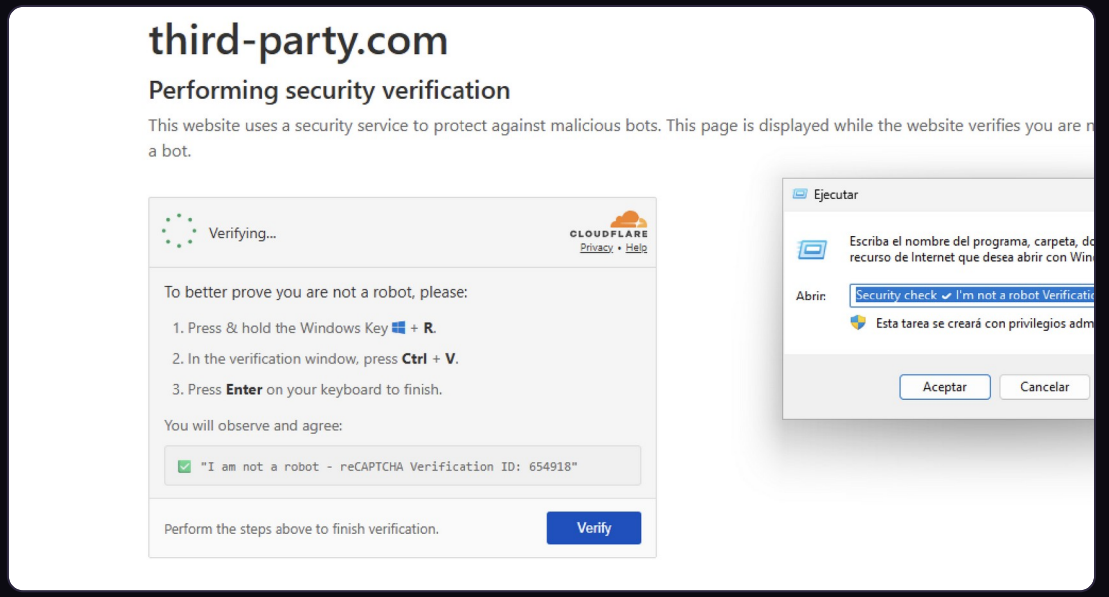
The victim runs it. No attachment, no exploit.

Sources: Microsoft DDR 2025 · ESET Threat Report H1 2025 · Push Security (2026) · CTM360 (Sep 2026)

THE CLICKFIX CASE

The lure: Win+R, Ctrl+V, Enter

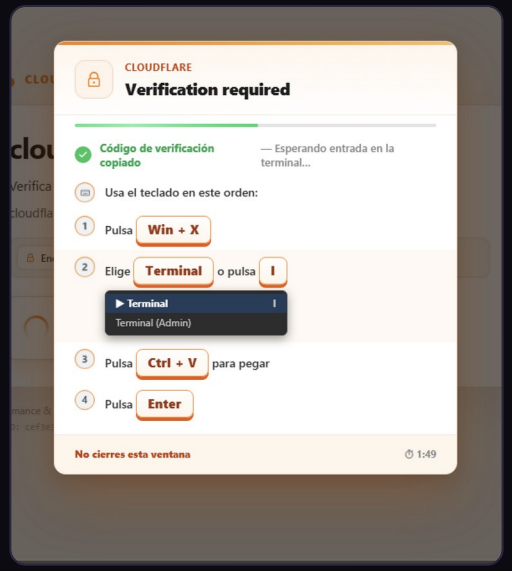


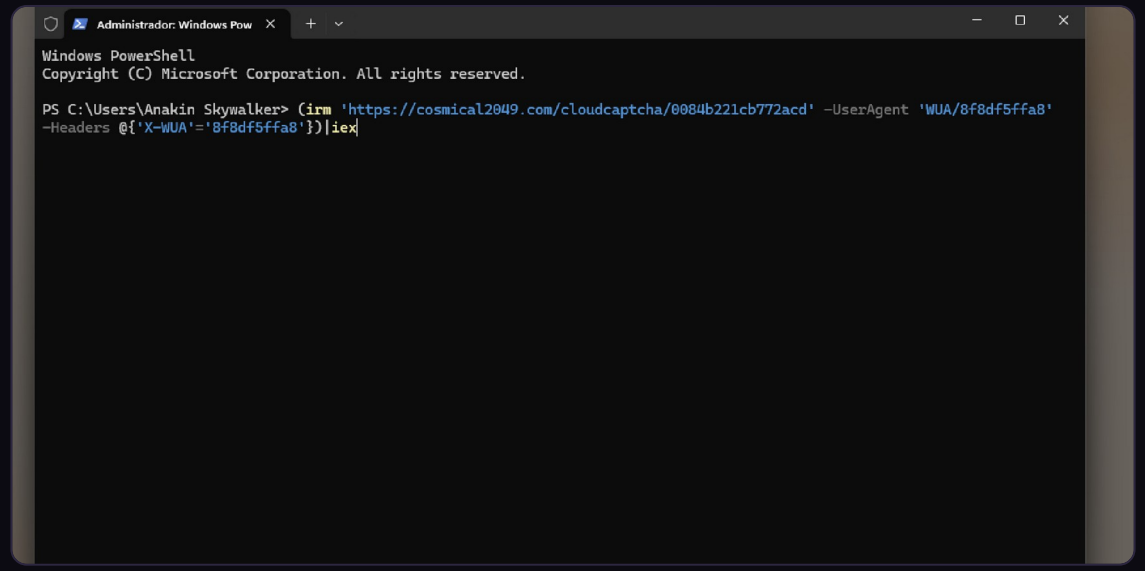


The “Verification ID” is the disguise: what the victim pastes is a command.

third-party[.]com, captured on 2026-10-12 in our own sandbox. The clipboard is not logged: telemetry sees the paste, never the page.

The variant: Win+X → Terminal





Win+X → Terminal skips the Run dialog: nothing lands in RunMRU and, if the command runs inside PowerShell, not as a command line either.

cloudflare[.]vc, 2026-10-12. The command fetches stage 1 from cosmical2049[.]com and only works with the right User-Agent and X-WUA header.

THE CLICKFIX CASE

The reality: the alert came at step 7

T+0:00	**Pastes the command**	PowerShell downloads a script from an IP written in decimal notation.	INFO
T+0:03	**Hidden console**	The window disappears: the user thinks it failed and retries.	INFO
T+0:05	**Silent MSI**	An installer from %TEMP%, with no windows.	INFO
T+0:07	**Hidden PowerShell**	Launched by the installer itself (msiexec).	INFO
T+0:22	**Persistence**	An injected .NET binary registers a fake Chrome extension.	INFO
T+0:26	**C2 connection**	Another .NET binary goes out over HTTP. The IP was on a reputation list.	BLOCKED
T+4:51	**The alert**	Reaches the SOC console.	ALERT

The only thing that alerted was a known IOC. Everything else was in the telemetry as “info”.

Times relative to the first paste, per EDR telemetry. Victim data anonymized.

THE CLICKFIX CASE

The sandbox said: “No threats detected”

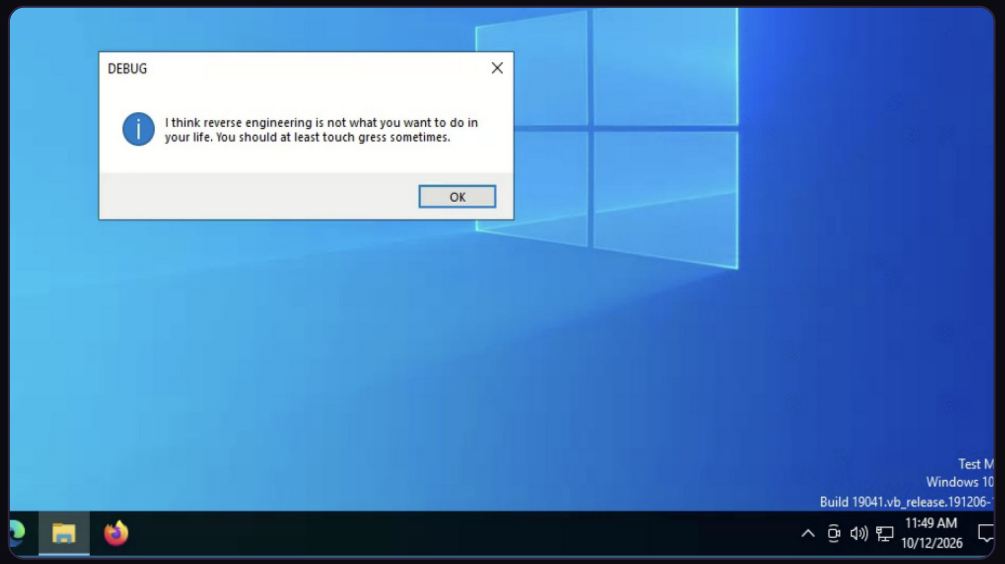
ANY.RUN verdict on stage 1

No threats detected

BUT THE BEHAVIOR SAID OTHERWISE

- ⚠ Changes the AMSI initialization state · T1562.001
- ⚠ Sets ServicePointManager.SecurityProtocol · T1071
- ⚠ Converts values to bytes to decode · T1027

Two layers of evasion. The server only delivers with the right User-Agent, header and a token that, in our tests, did not work twice. The payload checks its environment and refuses to run if it detects analysis.



What the payload showed in the sandbox: a message for the analyst, not the chain.

A clean verdict is not the absence of a threat: it can be successful evasion.

THE HUNT IN SENTINEL

The exercise hypothesis

> If someone pasted a command from a ClickFix lure, we will see an interpreter launched by Explorer (Win+R) or by the browser (FileFix) with a download command and, seconds later, the chain that command triggers.

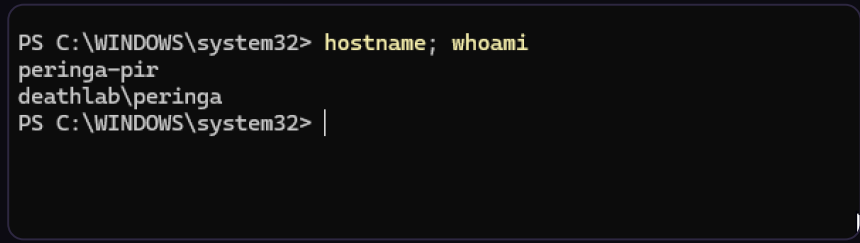
Data source	EDR processes, network, files and registry across the fleet: the events, not the alerts.
Positive control	Reproduce the pattern on a lab host and confirm the query finds it.
Confirmed by	A host with an interpreter that downloads and executes, followed by the chain it launches.
Refuted by	Zero results, with the query already validated against the positive control.
Known gap	The clipboard is not logged. RunMRU only sees Win+R; a paste into Terminal (Win+X) is only seen by Script Block Logging.
ATT&CK	T1204.004 → T1059.001 · T1564.003 · T1218.007 · T1055 · T1176.001

THE HUNT IN SENTINEL

Zero results without a positive control prove nothing

While preparing this workshop, nine queries in a row came back empty. This is how we diagnosed it:

1. **Does the table have data?**
   Yes: four hosts with registry events.
2. **Is my test event there?**
   No.
3. **Which accounts create processes on that host?**
   Other instructors'. Not mine.
4. **Is the test host in DeviceInfo?**
   No: it had no Defender sensor.



The positive control ran on the instructor workstation, which sends no telemetry. The query was fine; the host was not.

Before concluding "it's not there", prove the query finds what you know exists — on the right host.

THE HUNT IN SENTINEL

Seven chained queries

#	Question	What it looks for	Table
1	Did anyone paste a command?	Explorer or the browser launches an interpreter with a download command	DeviceProcessEvents
2	Why didn't they see it?	A Start-Process with -WindowStyle Hidden and the rest of the script's cmdlets	DeviceEvents · PowerShellCommand *
3	What came next?	msiexec launches a hidden PowerShell	DeviceProcessEvents
4	Who did it talk to?	A .NET binary (csc, ilasm) with an outbound connection	DeviceNetworkEvents
5	Did it locate itself?	A non-browser process checks its public IP	DeviceNetworkEvents
6	How does it stay?	A non-browser process modifies the Chrome profile	DeviceFileEvents
7	Next hunt	A manifest.json created outside the browser	DeviceFileEvents

Full queries in the workshop repo · * the lab doesn't ingest 4104: PowerShellCommand shows the cmdlets, not the script

THE HUNT IN SENTINEL

Query 1: the lineage of the paste

```
DeviceProcessEvents
| where TimeGenerated > ago(30d)
| where FileName in~ ("powershell.exe", "pwsh.exe",
"cmd.exe", "mshta.exe")
| where InitiatingProcessFileName in~ ("explorer.exe",
"chrome.exe", "msedge.exe", "firefox.exe")
| where ProcessCommandLine has_any ("irm", "iwr", "iex",
"Invoke-RestMethod", "Invoke-WebRequest",
"DownloadString", "http")
| project TimeGenerated, DeviceName, AccountName,
InitiatingProcessFileName, ProcessCommandLine
| sort by TimeGenerated asc
```

Why the browser

FileFix runs the command from the browser's file dialog: the parent is chrome.exe or msedge.exe.

What it does not see

A paste into an already open console (Win+X → Terminal): the parent is the console and, in PowerShell, the command is not even a command line. Script Block Logging sees it.

Validated in the lab

On Windows 11 the parent is explorer.exe, and RunMRU stores the full command.

THE HUNT IN SENTINEL

Noise is part of the story too

What you see	What it is	What to do
PowerShell -ExecutionPolicy AllSigned -NoProfile, launched by SenseIR.exe	The Defender sensor itself	Exclude by parent process
powershell -File ...\SYSVOL\...\Invoke-WEFClientSetup.ps1 with -encodedCommand	A Windows Event Forwarding GPO	Exclude by SYSVOL path, documented
DownloadFile from http://127.0.0.1/1.exe to invoice.exe	Another lab instructor's simulation	Inconclusive: ask, don't assume
mscopilot.exe and msedgewebview2.exe write Preferences	Copilot and WebView2 in their own profile	Justified exclusion in the rule

Document every false positive with its justification: that is what makes a detection reusable.

Rows 1–3: seen in the DEATHCon lab · row 4: model report case

WRITING THE STORY

From loose findings to a story

The hunt is done. Now tell it so someone can use it.

WRITING THE STORY

The structure of the report

1 **Executive summary**
What happened and what needs deciding, on one page.

2 **Hunting hypothesis**
The question, and what confirms or refutes it.

3 **Scope and limitations**
What was examined, what could not be seen, and with what confidence.

4 **Background**
The intelligence behind the hypothesis, with sources.

5 **MITRE ATT&CK**
Technique, tactic and evidence in the case.

6 **Methodology**
PEAK and how the queries were chained.

7 **Findings**
Verdict and evidence per query.

8 **Recommendations**
Actions with a priority, an owner and a status.

9 **Conclusion**
The whole story in one paragraph.

10 **Appendices**
IOCs, queries, timeline, controls and sources.

Full template in English and Spanish: github.com/Ank1nskywalker/Templates

WRITING THE STORY · BLUF

Executive summary: first things first

BEFORE · EXAMPLE

In September several queries were run in the EDR and suspicious PowerShell-related activity was observed on some hosts, which could be linked to ClickFix. Further investigation is recommended.

AFTER · MODEL REPORT

Hypothesis confirmed on one host (XXXX-01). A user pasted a command from a ClickFix lure into Win+R and, in under 30 seconds, a session-stealing Chrome extension was installed. The only alert arrived at T+4:51.

The verdict in the first line

Written for someone who doesn't read KQL

Numbers, not adjectives

WRITING THE STORY

Facts and assessments, kept apart

Fact · what the telemetry shows	Assessment · what we infer
csc.exe ran with no arguments and modified Secure Preferences.	Likely: code injected into a signed .NET binary.
explorer.exe wrote the same command to RunMRU four times.	Very likely: the user retried because the script hid the console.
Only one of the three C2s was on a reputation list, and it was the only one blocked.	Very likely: without a block, the other two are still reachable from the network.

A fact takes a past-tense verb and its source. An assessment takes a probability word and the reason why.

If the reader can’t tell what you saw from what you think, they can’t trust either.

WRITING THE STORY

Say how sure you are

PROBABILITY · ICD 203

Almost no chance	01–05 %
Very unlikely	05–20 %
Unlikely	20–45 %
Roughly even chance	45–55 %
Likely	55–80 %
Very likely	80–95 %
Almost certain	95–99 %

Confidence high, moderate or low: how solid the evidence is, not how likely the event is.

SOURCES · ADMIRALTY CODE

Source reliability

A · Completely reliable
B · Usually reliable
C · Fairly reliable
D · Not usually reliable
E · Unreliable
F · Cannot be judged

Information credibility

1 · Confirmed
2 · Probably true
3 · Possibly true
4 · Doubtful
5 · Improbable
6 · Cannot be judged

In the report: “High confidence that XXXX-01 was compromised: registry, process, network, file and sandbox evidence agree. Moderate confidence that no other hosts are affected: the main query only covers Win+R.”

Sources: ODNI, Intelligence Community Directive 203 · NATO / Admiralty grading system

WRITING THE STORY · ACH

Competing hypotheses: was it pasted?

Evidence	H1 · Pasted	H2 · Typed	H3 · Remote
Recorded in RunMRU, written by explorer.exe	Consistent	Consistent	Inconsistent
120 characters with a decimal IP, in seconds	Consistent	Inconsistent	Neutral
The same command, identical, four times	Consistent	Inconsistent	Consistent
No remote access tools in 24 h	Neutral	Neutral	Inconsistent
The browser visited a lure seconds earlier	Consistent	Neutral	Neutral

H1: pasted from a lure · H2: typed by hand · H3: launched by another process or a remote session

H1 is the only one with no evidence against it. ACH doesn't count support: it keeps the hypothesis that survives.

Method: R. J. Heuer, "Psychology of Intelligence Analysis" (CIA, 1999) · example based on the model report case

WRITING THE STORY

A hunt with no findings still gets reported

Zero results is a result, if you can prove the query works.

Coverage

Which hosts, which time window and which data sources.

Positive control

The evidence that the query finds the pattern you were looking for.

Gaps

What could not be seen: the clipboard, a channel with no telemetry, a source not ingested.

Next hypothesis

What you would look for if you had the missing visibility.

A report like this tells the decision-maker how much to trust the silence.

WRITING THE STORY · CHECKLIST

Before you hand it in

- ✓ The executive summary fits on one page and opens with the verdict.
- ✓ Every finding has a verdict, evidence and a confidence level.
- ✓ Facts are kept apart from assessments.
- ✓ Limitations and gaps are written down, not implied.
- ✓ Every recommendation has a priority, an owner and a status.
- ✓ The queries in the appendix can be re-run as they are.
- ✓ The victim's data is anonymized.
- ✓ The TLP is marked on the cover.

This is the rubric the exercise is graded against.

THE EXERCISE

Your turn

1. Log in to the workshop's Microsoft Sentinel lab.
2. Run the seed queries from the repo in order, starting with the positive control.
3. Classify every result: malicious, benign or inconclusive.
4. Write the report with the template. The executive summary goes first.
5. Share it on Discord and review it against the rubric.

WORKSHOP REPO

github.com/Ank1nskywalker/talks, folder 2026

TEMPLATE EN / ES

github.com/Ank1nskywalker/Templates

HINT

The lab is shared: scope by host and time window before you conclude.

Thank you

Every hunt leaves the next one behind.

Workshop: github.com/Ank1nskywalker/talks

Template: github.com/Ank1nskywalker/Templates

The campaign: M. H. Ali, “Arabic Streaming Websites ClickFix Campaign” (Oct 2026)

Frameworks: PEAK (Splunk SURGe, 2023) · Pyramid of Pain (Bianco, 2013) · ICD 203 (ODNI)

@anakinswal

